

# TrustSecAI

*Integrating Retrieval-Grounded Threat Intelligence, XAI,  
and Domain-Adaptive Language Models for Security Incident Assessment*

Rithvik Hemanth

PES2UG23CS484

Mentor: Prof. Nazmin Begum

**C3I Internship — Project Review**

Centre for Cognitive Computing and Computational Intelligence

# Problem Statement

## Limited Explainability

ML based IDS raise alerts but offer no human readable reasoning behind predictions.

## No Contextual Intelligence

Current systems do not link alerts to threat intelligence sources like MITRE ATT&CK or CVE databases.

## Analyst Burden

SOC analysts must manually correlate alerts with external knowledge, slowing incident response.

## Low Trust

Black box like automated systems reduce analyst confidence in acting on ML generated outputs.

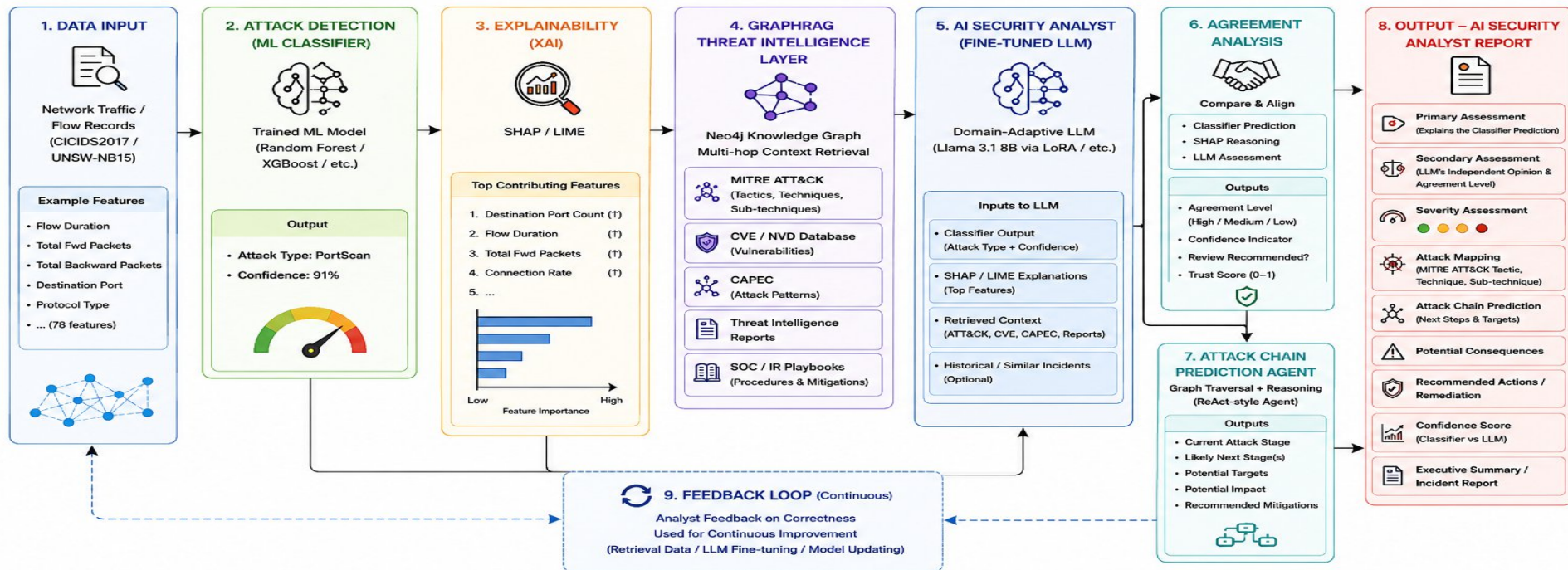
# Objectives

- 01** Develop an ML-based attack detection pipeline trained on CICIDS2017 and UNSW-NB15 capable of identifying malicious network activity.
- 02** Integrate XAI techniques (SHAP / LIME) to provide feature level explanations for classifier predictions, improving human interpretability.
- 03** Build a Graph based Retrieval-Augmented Generation (GraphRAG) layer using a Neo4j knowledge graph over MITRE ATT&CK, CVE/NVD, CAPEC, and SOC playbooks for structured multi hop threat retrieval.
- 04** Fine tune a domain adaptive LLM (LLaMA 3.1 8B via LoRA) on a hybrid cybersecurity corpus to act as an AI security analyst generating structured, confidence aware incident reports.
- 05** Evaluate how retrieval grounding, explainability, and domain adaptation collectively improve factual accuracy, trustworthiness, and actionability of AI-generated security assessments.

# Proposed Framework — System Architecture

## TrustSecAI – AI-Assisted Framework for Explainable and Context-Aware Security Incident Analysis

*From raw network traffic to proactive, actionable security intelligence for SOC analysts*



# Datasets

## CICIDS2017

*Training / Detection*

~2 GB of labeled network traffic flows covering common attack types (DoS, DDoS, Brute-force, PortScan, Web attacks).

## UNSW-NB15

*Training / Validation*

Modern network intrusion dataset with 9 attack categories and 49 features for robustness testing.

## MITRE ATT&CK

*RAG Knowledge Base*

Adversarial tactics, techniques, and procedures (TTPs) for contextual threat mapping during retrieval.

## CVE / NVD

*RAG Knowledge Base*

Vulnerability database used to enrich alerts with known CVEs and associated severity scores.

## Threat Intel Reports & SOC Playbooks

*RAG Knowledge Base*

Curated reports and response procedures to support actionable mitigation recommendations.

# Novelty & Key Contributions

01

## GraphRAG-Powered Threat Retrieval

Replaces flat RAG with a Neo4j knowledge graph over MITRE ATT&CK, CVE/NVD, and CAPEC, enabling structured multi-hop retrieval of attack context rather than simple document lookup.

02

## Classifier-LLM Agreement Analysis

A novel trust metric that measures alignment between the ML classifier's SHAP-derived reasoning and the LLM's contextual assessment, flagging cases where the two diverge as low-confidence alerts.

03

## Attack Chain Prediction Agent

A ReAct-style agentic module that traverses the CTI knowledge graph to predict likely next steps in an attack chain, enabling proactive rather than purely reactive incident response.

04

## Ablation Study on Trust Factors

Systematically evaluates how each component (GraphRAG, XAI, domain-adaptive LLM) individually contributes to factual accuracy, hallucination reduction, and actionability of generated assessments.

# Example Scenario — PortScan Detection

## INPUT

**Flow Duration:** 1200 ms

**Dest. Ports:** 850

**Conn. Attempts:** 1200

**Packet Rate:** High

## Classifier Output

**Attack:** PortScan

**Confidence:** 91%

## PROPOSED SYSTEM OUTPUT

### MITRE Mapping:

T1046 – Network Service Discovery | Tactic: TA0007 – Discovery

### Severity:

Medium

### Potential Consequences:

Network Mapping → Service Enumeration → Preparation for Exploitation

### Recommended Actions:

Investigate Source IP • Review Auth Logs • Monitor Follow-Up • Restrict Exposed Services

### Incident Summary:

Reconnaissance-oriented activity. May indicate preparation for subsequent intrusion. Immediate investigation recommended.

# Evaluation Metrics

## Detection Performance

- Accuracy, Precision, Recall, F1-Score
- False Positive Rate (FPR)
- Per-class classification metrics

## Explainability Quality

- SHAP / LIME feature consistency
- Human-interpretability rating (analyst feedback)

## RAG & LLM Quality

- Factual accuracy (vs. ground truth threat intel)
- Hallucination rate
- Answer Quality / Coherence

## Actionability & Trust

- Actionability score (usefulness to SOC)
- Analyst trust & confidence rating
- Classifier vs. LLM agreement analysis



# References

XAI For IDS

Explainable Intrusion Detection Systems (X-IDS): A Survey of Current Methods, Challenges, and Opportunities

XAI Survey

Explainable Artificial Intelligence in Cybersecurity: A Survey

GraphCyRAG

Retrieval Augmented Generation for Robust Cyber Defense

Threat Intelligence  
KG

CTI-Thinker: an LLM-driven system for CTI knowledge graph construction and attack reasoning

LLM Security  
Analyst

Uncovering Vulnerabilities of LLM-Assisted Cyber Threat Intelligence

LLM / Cybersecurity

*[Author et al., Year] — Title of paper on SOC automation / AI-assisted incident response. Journal/Conference.*

# Current Status & Next Steps

## Completed

- Project scope and HLD defined
- Datasets identified (CICIDS2017, UNSW-NB15, MITRE ATT&CK, CVE/NVD)
- Framework architecture finalized (7-stage pipeline)
- Literature survey in progress

## Next Steps

- Data preprocessing and feature engineering on CICIDS2017
- Train baseline ML classifiers (RF / XGBoost)
- Integrate SHAP/LIME for explainability layer
- Build GraphRAG pipeline — Neo4j KG construction over MITRE ATT&CK, CVE/NVD, and CAPEC
- LoRA fine-tune LLaMA 3.1 8B on hybrid cybersecurity corpus (CTI reports, ATT&CK, playbooks, synthetic incident reports)
- Build attack chain prediction agent + end-to-end integration, ablation study, and evaluation